

100 Days of Azure DevOps

Day 70 Handout — Speed without security is just a faster incident — identity, then RBAC, then the hotel safe

7 - Security, Compliance & Governance · Personal lab only · Educational content · Not a sales pitch

Architecture A — Phase 7 map (order is the product)

Layer	Object	Done looks like
Identity	Entra tenant, day61-lab appld	Personal directory; no secret in git
RBAC	Reader/Contributor at RG, not Owner at sub	Scope sentence you can say out loud
Robot badge	lab-sc = WIF service connection + SP	Not the same object as the app registration blade
Safe	Key Vault RBAC + DemoSecret dummy + pipeline fetch	Length in logs, not letters
Guardrails	Policy Deny/Audit + Security stage + approvals	Compliance blade + Deploy skipped on red scan

Architecture B — mini project scope (one pipeline, one policy, no theatre)

Piece	Include	Exclude
Pipeline	AzureKeyVault@2 or linked group; Security before Deploy; environment approval	A second CD platform to look busy
Policy	Require env tag on RGs, assignment visible	Custom policy JSON and three initiatives
Secret	Dummy DemoSecret only	Real passwords, work Key Vaults
Identity leftovers	Strip Owner from lab-sc	Creating more SPNs 'for completeness'
Evidence	docs/phase7-recap.md + screenshots without values	LinkedIn photo of a secret blade

Architecture C — recap failures that still look like a security week

Failure	What you see	Fix
Secret in YAML	\$(password): hunter2 still in git	Fetch only; rotate if it was real (it should not be)
Policy assigned nowhere	Doc says Policy; Compliance is empty	Show the assignment and a tagged RG
Approvals off	deployment job without environment	environment: lab with your approval
Owner SPN remains	Wizard gift from Day 63	Remove it as part of done
Work tenant evidence	Employer directory in the recap	Delete the post draft; personal only

One-liner to remember

Phase 7 recap: speed without security is just a faster incident. Done = secret not in YAML, a policy you can see, approvals on, robot not Owner.

Step-by-step lab (personal Azure / Azure DevOps only)

Personal subscription + azure-100-labs. Mini project is a demo, not a SIEM. Definition of done is written below.

- 1 Run one pipeline that fetches DemoSecret (length only) and has stages Build → Security → Deploy with environment: lab approval.
- 2 Confirm Policy assignment from Day 66 still exists (or re-assign require tag). Compliance blade shows the lab scope.
- 3 Confirm lab-sc is WIF, not Owner at subscription, and has Secrets User on the vault.
- 4 Confirm main is PR-protected and no secret values live in YAML/Library screenshots.

- 5 Write docs/phase7-recap.md: bouncer list → scoped badges → hotel safe → Policy effect → Security stage. Screenshot without secret values.
- 6 Tear down junk RGs from the policy experiment if they remain. Keep the vault only if you still need it for Phase 8 — else delete dummy secrets first.

Definition of done — Phase 7

```
# Done when all are true:
# 1. DemoSecret is not a YAML literal; job prints length only
# 2. Policy assignment visible (tagName=env); effect named (Deny or Audit)
# 3. Deploy is a deployment job with environment: lab approval
# 4. lab-sc = WIF; Contributor (or less) on one RG; Secrets User on the vault
# 5. main requires PR; Security dependsOn Build; Deploy dependsOn Security
# 6. docs/phase7-recap.md exists; no secret values in it
```

Done checklist

- Secret not in YAML; policy visible; approvals on
- Can explain app registration vs service connection vs RBAC scope
- Owner SPN leftover removed or documented as absent
- Phase 7 recap doc on the personal repo

Tomorrow — Day 71

Azure Monitor fundamentals — the flashlight, not the fix